

IP Strategy: Patentable & Research-Worthy Innovations

This document outlines the technical claims and research methodologies required to elevate the project from a functional tool to a patentable innovation or a peer-reviewed research contribution.

1. Primary Innovation: Autonomous Agentic Pentesting & Exploit Validation (AAEV)

The Problem: Traditional Static Analysis (SAST) suffers from high false-positive rates, leading to developer distrust.

The Solution: A "Closed-Loop" system that uses Agentic AI to autonomously prove exploitability by generating functional Proof-of-Concept (PoC) scripts.

Competitive Landscape (Market Status 2026):

To establish novelty, the following market leaders were analyzed:

- **Horizon3.ai (NodeZero):** Focuses on autonomous "Black-Box" network pentesting. It identifies reachable paths through a network but does not generate PoCs based on static source code analysis.
- **Pentera:** Automated security validation platform. Primarily operates on infrastructure and network layers (DAST/VAPT) rather than deep source-code logic (SAST).
- **Checkmarx / Snyk:** These platforms utilize AI for "Triage" (filtering bugs) and "Remediation" (fixing bugs), but they currently do not provide an integrated engine that autonomously writes and executes exploits to verify findings.

The Technical Gap (Your Project's Novelty):

Existing tools are either **Detectors** (Snyk/Semgrep) or **Network Attackers** (Horizon3). Your project occupies the "White-Box Attack" gap:

1. It analyzes the code (White-Box).
2. It reasons about the logic (Agentic AI).
3. It autonomously writes an exploit script.
4. It executes the script against the code in a sandbox (Validation).

This "Code-to-Exploit" pipeline is currently a major research area with minimal commercial implementation.

Patentable Claims:

- **Claim 1:** A method for vulnerability validation comprising the detection of a potential flaw via static analysis and the autonomous generation of a targeted Proof-of-Concept (PoC) exploit script via a Large Language Model (LLM).
- **Claim 2:** The use of an ephemeral, isolated container environment (Docker) to execute the generated PoC against the cloned source code to verify "Success" or "Failure" of the exploit.
- **Claim 3:** A feedback loop where the results of the PoC execution are fed back to the normalization layer to dynamically adjust the "Risk Score" (CVSS) of the finding.

Research Methodology:

- Conduct a comparative study: Run standard scanners vs. the AAEV Engine on 100 vulnerable repositories.
 - **Metric:** Measure the reduction in "Developer Triage Time" when findings are accompanied by a verified PoC script.
-

2. Secondary Innovation: Context-Aware "Architecturally Compliant" Remediation

The Problem: AI-generated fixes often ignore local coding styles, custom libraries, or internal frameworks, leading to "Fix Rejection."

The Solution: An AI engine constrained by a "Codebase Knowledge Graph."

Patentable Claims:

- **Claim 1:** A system for generating software patches that are semantically and stylistically consistent with a target repository by pre-processing the repository into a hierarchical knowledge graph.
- **Claim 2:** A dynamic prompting mechanism that injects "Local Architectural Constraints" (e.g., specific DB wrappers or logging patterns) into the LLM's remediation logic.

Research Methodology:

- Perform an "A/B Test" with 50 developers. Group A receives generic AI fixes; Group B receives "Graph-Constrained" fixes.
 - **Metric:** Compare the "Acceptance Rate" and "Manual Refactoring Required" between both groups.
-

3. High-Value "Black Area": Normative Compliance Mapping (NCM)

The Problem: There is a manual gap between finding a technical bug (e.g., SQLi) and proving compliance with legal frameworks (e.g., GDPR Article 32 or SOC2).

The Solution: Automated mapping of technical findings to regulatory control objectives.

Patentable Claims:

- **Claim 1:** An automated engine that utilizes semantic analysis to map low-level technical vulnerabilities to high-level regulatory compliance requirements (NIST, ISO 27001, HIPAA).
 - **Claim 2:** The generation of a "Compliance Heatmap" that calculates organizational risk based on the density of vulnerabilities within specific regulatory domains.
-

Summary for Presentation/Viva:

To defend the "Novelty" of this project, emphasize that it is not a "Wrapper," but a **Verification Engine**. While others only **detect**, our platform **validates** through autonomous attack simulation and **remediates** through architecturally-aware AI agents.